

INFORMATION SECURITY MANAGEMENT SYSTEM

SCOPE STATEMENT

Tumaini Capital Ltd | ISO/IEC 27001:2022 — Clause 4.3 | Document ID: ISMS-DOC-001 | Fictional case study

Document Control

Document Title	ISMS Scope Statement	Document ID	ISMS-DOC-001
Version	1.0	Status	<i>DRAFT — Pending Management Approval</i>
Prepared by	GRC Consultant	Date Prepared	June 2026
Approved by	CEO, Tumaini Capital Ltd	Next Review Date	June 2027 (or on material change)
Related Documents	ISMS-DOC-002: Context Document (Clauses 4.1 & 4.2) ISMS-DOC-003: Boundary Determination Worksheet ISMS-DOC-004: Scope Decision Log		

1. PURPOSE

This document defines the scope of Tumaini Capital Ltd.’s Information Security Management System (ISMS) in accordance with Clause 4.3 of ISO/IEC 27001:2022. The scope has been determined on the basis of the external and internal context established in the Context Document (ISMS-DOC-002) and the requirements of interested parties identified therein.

This scope statement is a mandatory controlled document. It must be approved by top management, maintained as documented information, and made available to the certification body at Stage 1 audit.

2. FORMAL SCOPE STATEMENT

The Information Security Management System of Tumaini Capital Ltd covers the digital lending platform (mobile application and USSD channel), the core lending engine and its supporting AWS infrastructure, the Customer Relationship Management (CRM) system, and all customer and borrower data processed therein, including KYC documentation for the SME lending product. The scope includes the Nairobi (Upper Hill) headquarters and the Kisumu office, both of which house staff with access to in-scope systems.

The scope includes information accessed or processed via personally-owned mobile devices used for business purposes, governed by policy-based controls; the underlying hardware and operating systems of such devices are excluded, as the organization does not own or have technical authority over them.

Interfaces with the Safaricom M-Pesa API, two credit reference bureaus, and the outsourced IT managed service provider are included as third-party interfaces subject to supplier risk management; the internal systems of those third parties fall outside Tumaini Capital's ISMS boundary. The Human Resources and Payroll system is excluded from this certification cycle on the basis that it falls outside the primary risk drivers necessitating certification; it remains subject to baseline security policies and the Data Protection Act, 2019.

3. ORGANIZATIONAL BOUNDARY

The following business units and functions fall within the ISMS boundary:

Business Unit / Function	In ISMS Scope	Basis for Inclusion
Risk & Compliance	Yes	Owns ISMS governance, regulatory compliance, and policy; central to all three certification drivers.
Engineering	Yes	Manages the core lending platform, AWS infrastructure, and CRM; owns technical controls implementation.

Business Unit / Function	In ISMS Scope	Basis for Inclusion
Operations	Yes	Process owner for loan disbursement and customer interactions; directly touches in-scope borrower data.
HR / Finance	No (this cycle)	Processes employee data only; not linked to the certification drivers. Excluded with documented justification.
Outsourced IT MSP	No (managed interface)	External third party; governed by supplier risk management and contractual obligations, not an internal org unit.

4. PHYSICAL BOUNDARY

The following locations fall within the ISMS boundary:

Location	In ISMS Scope	Notes
Nairobi HQ (Upper Hill)	Yes	Primary site; houses all in-scope business units.
Kisumu Office	Yes	Staff have remote access to CRM and core lending platform.
AWS eu-west-1 (Ireland)	Yes — logical layer	Physical/environmental controls covered by AWS's own ISO 27001/SOC 2 attestation. Tumaini is responsible for logical configuration, access control, and data security within its AWS environment.
Employee personal devices (hardware)	No	Tumaini does not own the devices; information accessed via BYOD is in scope via policy-based controls.

5. INFORMATION SYSTEMS BOUNDARY

The following systems, applications, and data stores fall within or interface with the ISMS boundary:

System / Application	Classification	Data Processed	Basis
Digital Lending Platform (App + USSD)	In Scope	Loan application & KYC data	Primary borrower-facing product; processes all in-scope customer data.
Core Lending Engine + AWS Infrastructure	In Scope	Loan, repayment & disbursement data	Core processing system; hosted on AWS eu-west-1 under shared responsibility model.
CRM System	In Scope	Customer contact & account data	Repository of in-scope customer data; site of the 2025 unauthorized access incident.
Google Workspace (email & drives)	In Scope (policy-governed)	Internal comms & working documents	Multi-purpose platform; organizational data and usage governed by Acceptable Use Policy.
WhatsApp Business	In Scope (policy-governed)	Customer-facing communications	Governed by Acceptable Use Policy; platform infrastructure is a third-party interface.
Safaricom M-Pesa API	Third-Party Interface	Disbursement & repayment transactions	Managed via supplier risk register and API security controls.
Credit Reference Bureaus (x2)	Third-Party Interface	Credit history queries	Data shared under signed data-sharing agreements with access logging.
HR / Payroll System	Excluded (this cycle)	Employee personal & payroll data	Not linked to certification drivers; excluded with documented justification.

6. EXCLUSIONS AND JUSTIFICATIONS

The following items are explicitly excluded from the ISMS boundary. All exclusions are documented with justification as required by Clause 4.3. No exclusion removes Tumaini Capital's legal obligations under applicable law.

Item	Reason for Exclusion	Controls Still Applicable
HR / Payroll System	Not linked to any of the three certification drivers (bank due-diligence requirement, ODPC enforcement focus on lending data, or CRM access incident). Extending scope to employee data processing would add significant audit overhead without addressing the identified risks within the 12-month timeline.	Baseline information security policies (access control, backup, encryption at rest) continue to apply. Employee data remains subject to the Data Protection Act, 2019. HR/Payroll will be considered for inclusion in the next ISMS scope review cycle.
BYOD Device Hardware & Operating Systems	Tumaini Capital does not own or have technical authority over personally-owned mobile devices. Device-level controls (patch levels, encryption state, OS hardening) cannot be consistently evidenced for hardware the organization does not control.	Organizational information accessed or processed via personal devices remains in scope and is governed by the Acceptable Use / BYOD Policy. Conditional access, screen-lock requirements, and remote-wipe of the corporate data container apply as policy-based controls.
Internal Systems of Third-Party Suppliers (M-Pesa, Credit Bureaus, MSP, AWS Physical Infrastructure)	Tumaini Capital does not control the internal information security posture of its third-party suppliers. Their internal systems fall outside the ISMS boundary.	Third-party interfaces are managed through supplier risk management controls, contractual information security obligations, and the monitoring of supplier security certifications (e.g. AWS ISO 27001 / SOC 2 attestation).

7. INTERFACES AND DEPENDENCIES

The following interfaces exist between the ISMS boundary and external parties. These are not in scope for certification but are subject to supplier risk management controls under Annex A controls 5.19–5.22 of ISO/IEC 27001:2022:

- Safaricom Limited (M-Pesa API) — disbursement and repayment transaction processing
- Credit Reference Bureau Africa (CRBA) and Metropol — credit history data exchange
- Outsourced IT Managed Service Provider — device provisioning and office network management
- Amazon Web Services (AWS) — cloud infrastructure hosting under shared responsibility model

8. REVIEW AND MAINTENANCE

This scope statement shall be reviewed:

- Annually as part of the ISMS management review (Clause 9.3)
- Following any material change to the business, such as a new office, product line, system, or outsourcing arrangement
- Following a significant security incident that reveals a gap in the current boundary
- Prior to each certification or surveillance audit

Proposed changes to the scope must be reviewed by the ISMS Lead and approved by the CEO before the updated statement is issued as a new controlled version.

9. MANAGEMENT APPROVAL

By signing below, the named individuals confirm that this scope statement accurately describes the boundary of Tumaini Capital's ISMS, that they have reviewed the exclusions and are satisfied the justifications are sound, and that they commit the organization to maintaining and continually improving the ISMS within this defined scope.

Role	Name	Signature	Date
ISMS Lead (Head of Risk & Compliance)			
Top Management Sponsor (Chief Executive Officer)			